

LiveCare AR — Tehdit ve Hata Güvenliği Raporu (THS Report)

Threat and Hazard Safety Analysis

Hazırlanma Tarihi: Haziran 2026 | **Proje:** LiveCare AR (PWA + AR + AI)
Standart Referans: IEC 62443, OWASP Top 10, ISO/IEC 27001, ISO 14971 (Tıbbi Cihaz Risk Yönetimi)

Yönetici Özeti

Bu rapor, **LiveCare AR** uygulamasına yönelik sistematik bir tehdit ve tehlike analizi sunmaktadır. Analiz; bilgi güvenliği tehditleri, fonksiyonel tehlikeler, tıbbi güvenlik riskleri ve gizlilik tehditleri olmak üzere dört ana eksen üzerinde yapılandırılmıştır.

LiveCare AR, karaciğer nakli hastalarına yönelik olduğu için olası bir güvenlik başarısızlığının sonuçları doğrudan insan sağlığını etkileyebilmektedir. Bu durum, uygulamanın olağan tüketici yazılımlarına kıyasla çok daha titiz bir tehdit modellemesi gerektirdiği anlamına gelmektedir.

1. Tehdit Modelleme Metodolojisi

Bu raporda **STRIDE** tehdit modelleme çerçevesi kullanılmıştır:

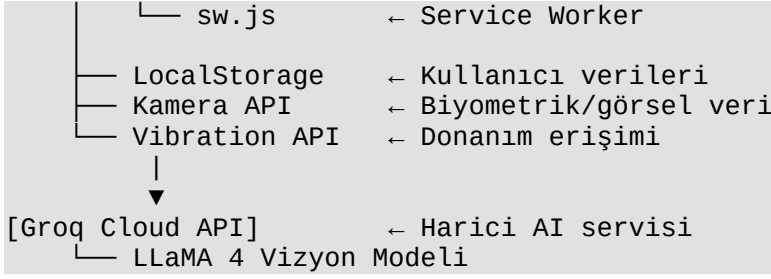
Kısaltma	İngilizce	Türkçe
S	Spoofing	Kimlik sahtekârlığı
T	Tampering	Veri manipülasyonu
R	Repudiation	İnkar edilebilirlik
I	Information Disclosure	Bilgi ifşası
D	Denial of Service	Hizmet reddi
E	Elevation of Privilege	Ayrıcalık yükseltme

Risk düzeyi: **Kritik (K)** / **Yüksek (Y)** / **Orta (O)** / **Düşük (D)**

2. Sistem Bileşenleri ve Saldırı Yüzeyi

2.1 Bileşen Haritası

[Kullanıcı Cihazı]	
—	Tarayıcı (Chrome/Safari/Firefox)
—	index.html ← Ana uygulama
—	ar.html ← AR sahnesi
—	script.js ← Uygulama mantığı + API anahtarı
—	style.css ← Sunum katmanı



2.2 Güven Sınırları

Sınır	Açıklama	Güven Düzeyi
Cihaz ↔ Tarayıcı	Yerel çalışma ortamı	Yüksek
Tarayıcı ↔ Service Worker	Aynı origin, kısıtlı	Orta-Yüksek
Tarayıcı ↔ Groq API	İnternet üzerinden	Düşük
Kullanıcı ↔ Uygulama	Kimlik doğrulama yok	Düşük

3. Tehdit Kataloğu

3.1 Bilgi Güvenliği Tehditleri

TH-001: API Anahtarı İfşası

Alan	Detay
STRIDE Kategorisi	Information Disclosure (I)
Tehdit Tanımı	Groq API anahtarı <code>script.js</code> dosyasında açık metin olarak bulunmaktadır. Herhangi bir kullanıcı tarayıcı DevTools ile bu anahtara erişebilir.
Etkilenen Bileşen	<code>script.js</code>
Saldırı Vektörü	Tarayıcı Developer Tools → Sources → <code>script.js</code>
Olasılık	Çok Yüksek
Etki	API kotasının tükenmesi; ücretli kullanım; hesap askıya alma
Risk Düzeyi	KRİTİK
Mevcut Kontrol	Yok
Önerilen Kontrol	Vercel/Netlify Serverless Function üzerinden backend proxy; ortam değişkeni (<code>process.env</code>) kullanımı

TH-002: LocalStorage Veri Manipülasyonu

Alan	Detay
STRIDE Kategorisi	Tampering (T)
Tehdit Tanımı	Cihaza fiziksel erişimi olan bir kişi tarayıcı konsolundan LocalStorage verilerini (ilaç saatleri, görev durumları) değiştirebilir.
Etkilenen Bileşen	localStorage
Saldırı Vektörü	<code>localStorage.setItem('medicines', '[{"name":"yanlış ilaç"}]')</code>
Olasılık	Orta
Etki	Yanlış ilaç saati bildirimi; hayati risk
Risk Düzeyi	YÜKSEK
Mevcut Kontrol	Yok
Önerilen Kontrol	Veri bütünlüğü kontrolü (HMAC/checksum); kullanıcı kimlik doğrulama

TH-003: XSS (Cross-Site Scripting)

Alan	Detay
STRIDE Kategorisi	Tampering (T), Elevation of Privilege (E)
Tehdit Tanımı	Kullanıcı girdisi (ilaç adı, saat) sanitize edilmeksizin DOM'a yansıtılıyorsa XSS açığı oluşabilir.
Etkilenen Bileşen	<code>script.js</code> DOM manipülasyon fonksiyonları
Saldırı Vektörü	İlaç adı alanına <code><script>alert(1)</script></code> girilmesi
Olasılık	Düşük-Orta
Etki	Oturum ele geçirme; kötü amaçlı kod çalıştırma
Risk Düzeyi	ORTA
Mevcut Kontrol	Kısmi (textContent kullanımı bazı yerlerde)
Önerilen Kontrol	DOMPurify kütüphanesi; CSP header; <code>innerHTML</code> yerine <code>textContent</code> kullanımı

TH-004: Sahte Groq API Yanıtı (Response Spoofing)

Alan	Detay
STRIDE Kategorisi	Spoofing (S), Tampering (T)
Tehdit Tanımı	MITM saldırısı veya DNS zehirlenmesi ile Groq API yanıtı manipüle edilerek yanlış yemek analizi sonucu gösterilebilir.

Alan	Detay
Etkilenen Bileşen	AI yemek analizi modülü
Saldırı Vektörü	MITM proxy; DNS spoofing
Olasılık	Çok Düşük
Etki	Zararlı gıdanın "UYGUN" olarak gösterilmesi; hayati risk
Risk Düzeyi	YÜKSEK
Mevcut Kontrol	HTTPS
Önerilen Kontrol	Certificate pinning (uygulanabilir ise); yanıt doğrulama şeması; sorumluluk reddi uyarısı

TH-005: Kamera Görüntüsü Sızıntısı

Alan	Detay
STRIDE Kategorisi	Information Disclosure (I)
Tehdit Tanımı	Kamera akışı Base64 olarak Groq API'ye gönderilmektedir. Bu görüntü sunucu tarafında loglanabilir veya üçüncü taraflarla paylaşılabilir.
Etkilenen Bileşen	AI modülü kamera entegrasyonu
Olasılık	Orta
Etki	Kişisel veri ihlali; KVKK yaptırımı
Risk Düzeyi	YÜKSEK
Mevcut Kontrol	HTTPS iletim şifrelemesi
Önerilen Kontrol	Groq veri işleme politikası incelenmeli; KVKK kapsamında açık rıza alınmalı

3.2 Fonksiyonel Tehlikeler

TH-006: Service Worker Önbellek Zehirlenmesi

Alan	Detay
STRIDE Kategorisi	Tampering (T)
Tehdit Tanımı	Kötü amaçlı bir script, Service Worker önbelleğine sahte içerik enjekte edebilir.
Etkilenen Bileşen	sw.js
Risk Düzeyi	ORTA
Önerilen Kontrol	Cache sürüm numaralandırma; bütünlük doğrulaması

TH-007: AR Modülü Hizmet Reddi

Alan	Detay
STRIDE Kategorisi	Denial of Service (D)
Tehdit Tanımı	Kötü hazırlanmış bir marker görüntüsü AR.js render döngüsünü sonsuz döngüye sokabilir ve tarayıcıyı dondurabilir.
Etkilenen Bileşen	ar.html — AR.js
Risk Düzeyi	DÜŞÜK
Önerilen Kontrol	AR.js güncel versiyonu; render timeout mekanizması

3.3 Tıbbi Güvenlik Tehditleri

TH-008: Yanlış Yemek Sınıflandırması (AI Hallucination)

Alan	Detay
Tehdit Tanımı	LLaMA 4 vizyon modeli, karaciğer nakli hastası için son derece tehlikeli olan greyfurtu "uygun" olarak sınıflandırabilir.
Etkilenen Modül	AI Yemek Analizi
Olasılık	Orta (AI modelleri %5-10 hata oranına sahip olabilir)
Etki	İlaç etkileşimi → Organ reddi → Ölüm
Risk Düzeyi	KRİTİK
Mevcut Kontrol	Yok
Önerilen Kontrol	Her sonuçta zorunlu sorumluluk reddi; doktor onayı çağırısı; yüksek riskli besin listesi için kural tabanlı ek doğrulama

TH-009: Eksik veya Hatalı Acil Durum Bilgisi

Alan	Detay
Tehdit Tanımı	Acil durum modülündeki telefon numaraları güncel olmayabilir veya belirtilerin bir kısmı eksik listelenmiş olabilir.
Etkilenen Modül	Acil Durum Rehberi
Olasılık	Düşük
Etki	Organ reddi belirtisinin geç fark edilmesi; hayati tehlike
Risk Düzeyi	YÜKSEK

Alan	Detay
Önerilen Kontrol	6 ayda bir tıbbi içerik güncellemesi; transplant uzmanı onayı

TH-010: İlaç Hatırlatıcı Hatalı Girişi

Alan	Detay
Tehdit Tanımı	Kullanıcı yanlış ilaç adı veya saati girebilir. Uygulama girişi doğrulamaz.
Etkilenen Modül	İlaç Saatleri Takibi
Olasılık	Yüksek
Etki	Yanlış zamanlı ilaç alımı; Takrolimus dozu kayması → Organ reddi
Risk Düzeyi	YÜKSEK
Önerilen Kontrol	İlaç adı önerileri (whitelist); dozlama uyarısı; doğrulama adımı

3.4 Gizlilik Tehditleri (KVKK/GDPR)

TH-011: Yetersiz Kullanıcı Rızası

Alan	Detay
Yasal Dayanak	KVKK Md. 5, 6; GDPR Art. 7, 9
Tehdit Tanımı	Kamera görüntüsü (biyometrik veri kapsamında değerlendirilebilir) kullanıcıdan açık rıza alınmadan Groq API'ye iletilmektedir.
Risk Düzeyi	KRİTİK
Önerilen Kontrol	Uygulama ilk açılışında açık rıza arayüzü; veri işleme aydınlatma metni; rızayı geri alma mekanizması

TH-012: Veri Saklama Politikası Belirsizliği

Alan	Detay
Yasal Dayanak	KVKK Md. 7; GDPR Art. 5(e)
Tehdit Tanımı	Groq API'nin kamera görüntülerini ne kadar süre sakladığı belirsizdir.
Risk Düzeyi	YÜKSEK
Önerilen Kontrol	Groq Veri İşleme Sözleşmesi (DPA) imzalanmalı; kullanıcıya bilgi verilmeli

4. Risk Matrisi

ID	Tehdit	Olasılık	Etki	Risk Düzeyi
TH-001	API Anahtarı İfşası	Çok Yüksek	Yüksek	KRİTİK
TH-002	LocalStorage Manipülasyonu	Orta	Yüksek	YÜKSEK
TH-003	XSS Açığı	Düşük-Orta	Orta	ORTA
TH-004	Sahte API Yanıtı	Çok Düşük	Çok Yüksek	YÜKSEK
TH-005	Kamera Görüntüsü Sızıntısı	Orta	Yüksek	YÜKSEK
TH-006	SW Önbellek Zehirlenmesi	Düşük	Orta	ORTA
TH-007	AR DoS	Çok Düşük	Düşük	DÜŞÜK
TH-008	Yanlış AI Sınıflandırması	Orta	Çok Yüksek	KRİTİK
TH-009	Hatalı Acil Bilgisi	Düşük	Çok Yüksek	YÜKSEK
TH-010	Hatalı İlaç Girişi	Yüksek	Yüksek	YÜKSEK
TH-011	Yetersiz KVKK Rızası	Yüksek	Yüksek	KRİTİK
TH-012	Veri Saklama Belirsizliği	Orta	Orta	ORTA

5. Azaltma Stratejileri — Öncelikli Eylem Planı

Faz 1 — Acil (0-1 Hafta)

Eylem	Hedef Tehdit
API anahtarını backend proxy'e taşı	TH-001
Her AI sonucuna tıbbi sorumluluk reddi ekle	TH-008
KVKK açık rıza akışı ekle	TH-011

Faz 2 — Kısa Vadeli (1-4 Hafta)

Eylem	Hedef Tehdit
DOMPurify ile XSS koruması	TH-003

Eylem	Hedef Tehdit
LocalStorage HMAC bütünlük kontrolü	TH-002
İlaç adı doğrulama ve whitelist	TH-010
Groq DPA sözleşmesi	TH-012

Faz 3 — Orta Vadeli (1-3 Ay)

Eylem	Hedef Tehdit
Tıbbi içerik periyodik güncelleme	TH-009
CSP header implementasyonu	TH-003, TH-006
Kural tabanlı yüksek riskli besin filtresi	TH-008
Penetrasyon testi	Tüm TH

6. Sonuç ve Öneriler

LiveCare AR'ın mevcut güvenlik durumu, bir sağlık uygulaması için **kabul edilemez risk düzeyi** içermektedir. Özellikle:

- TH-001 (API Anahtarı)** ve **TH-011 (KVKK Rızası)** kritik hukuki ve güvenlik açıklarıdır — hemen kapatılmalıdır.
- TH-008 (Yanlış AI Sınıflandırması)** tıbbi güvenlik açısından en yüksek etki potansiyeline sahiptir ve teknik + hukuki tedbirler birlikte alınmalıdır.
- Uygulama, TİTCK kapsamında **Sınıf I Tıbbi Yazılım** değerlendirmesinden geçirilmelidir.

Bu tehdit ve tehlike analizi, LiveCare AR'ın sorumlu ve güvenli bir sağlık uygulaması olarak geliştirilmesi için yol haritası niteliğindedir.

Bu rapor STRIDE metodolojisi ve ISO 14971 risk yönetim standardı referans alınarak hazırlanmıştır.